

DISEÑO DE API REST Y DOCUMENTACIÓN DE ENDPOINTS

Plataforma Web de Invitaciones Digitales Personalizadas

Versión: 1.0 | Fecha: 11 de marzo de 2026
Basado en: SRS v1.0 | Modelo de Negocio v1.1 | Seguridad y Datos v1.0
Stack: NestJS + TypeScript | PostgreSQL | Firebase Storage

Tabla de Contenidos

Tabla de Contenidos	2
1. Introducción	3
1.1 Arquitectura General	3
1.2 Convenciones de la API	3
2. Autenticación y Seguridad	4
2.1 Mecanismos de Autenticación	4
2.2 Flujo de Autenticación JWT	4
2.3 Cabeceras de Seguridad	4
3. Endpoints de la API	5
3.1 Módulo: Autenticación	5
POST /auth/login	5
3.2 Módulo: Tipos de Evento	6
GET /tipos-evento	6
POST /tipos-evento	6
3.3 Módulo: Templates	7
GET /templates	7
3.4 Módulo: Servicios	8
3.5 Módulo: Pedidos	9
POST /pedidos	9
PATCH /pedidos/:id/estado	10
3.6 Módulo: Invitaciones	11
POST /invitaciones	11
GET /invitaciones/:id/public	13
3.7 Módulo: Historia	14
POST /invitaciones/:id/historias	14
3.8 Módulo: Invitados y Confirmación de Asistencia	15
POST /invitaciones/:id/invitados	15
POST /invitaciones/:id/confirmar	15
GET /invitaciones/:id/asistentes	16
3.9 Módulo: Galería de Fotos	17
POST /invitaciones/:id/galeria	17
GET /invitaciones/:id/galeria/download	18
3.10 Módulo: Música	19
POST /invitaciones/:id/musica	19
3.11 Módulo: Notificaciones y Automatizaciones	20
Eventos que disparan notificaciones	20
Cron Job: Eliminación automática de datos	20
3.12 Módulo: Cálculo de Precios	21
POST /precios/calcular	21

4. Esquema de Respuestas y Manejo de Errores	22
4.1 Estructura de Respuesta Exitosa	22
4.2 Estructura de Error	22
4.3 Códigos de Estado HTTP	22
5. Esquema de Base de Datos	24
5.1 Entidad: Usuario	24
5.2 Entidad: TipoEvento	24
5.3 Entidad: Pedido	24
5.4 Entidad: Invitacion (Central)	26
5.5 Relaciones Principales	26
5.6 Entidades Complementarias	26
6. Validaciones y Sanitización	28
6.1 Validación en Capas	28
6.2 Sanitización HTML	28
6.3 Verificación MIME	28
6.4 Límites de Tamaño	28
7. Resumen Completo de Endpoints	29

1. Introducción

Este documento define el diseño completo de la API REST para la Plataforma Web de Invitaciones Digitales Personalizadas. Cubre la arquitectura, autenticación, endpoints, DTOs de request/response, códigos de error y esquema de base de datos. Está alineado con el SRS v1.0, el Modelo de Negocio v1.1, el documento de Seguridad y Datos v1.0, y los diagramas UML del sistema (actividad, entidad-relación y clases).

1.1 Arquitectura General

La plataforma sigue una arquitectura cliente-servidor con separación clara entre frontend y backend:

Frontend: React + TypeScript, desplegado en Vercel. SPA responsiva mobile-first.

Backend: NestJS + TypeScript, desplegado en Railway. API REST con validación en capas mediante DTOs.

Base de datos: PostgreSQL con TypeORM. Parámetros preparados para prevenir inyección SQL.

Almacenamiento: Firebase Storage para fotos de galería, fotos del anfitrión y archivos MP3.

Integraciones: Google Maps (embebido), Google Calendar (link), WhatsApp Web (wa.me/).

1.2 Convenciones de la API

Base URL: `https://api.invitaciones.com/v1`

Formato: JSON (application/json) para todos los endpoints excepto upload de archivos (multipart/form-data).

Versionado: Prefijo /v1 en la URL base.

Nomenclatura: Rutas en kebab-case, campos JSON en camelCase.

Paginación: Parámetros query `?page=1&limit=20` donde aplique.

Timestamps: Formato ISO 8601 (YYYY-MM-DDTHH:mm:ssZ).

Rate Limiting: 100 peticiones/minuto por IP. Header X-RateLimit-Remaining en cada respuesta.

Payload máximo: 16 MB por request.

2. Autenticación y Seguridad

2.1 Mecanismos de Autenticación

El sistema implementa tres niveles de acceso según el rol del usuario, tal como se define en la matriz de accesos del documento de Seguridad y Datos:

Panel de Administración (/admin): Autenticación obligatoria mediante usuario/contraseña. Contraseñas hasheadas con Argon2/bcrypt + salting. Sesiones gestionadas con JWT (JSON Web Tokens). Bloqueo temporal de IP tras 5 intentos fallidos.

Lista de Asistentes: Acceso protegido por contraseña única por evento, proporcionada por el administrador al anfitrión. No requiere registro de cuenta.

Invitaciones y Galería: Acceso público sin autenticación. URLs generadas con UUID v4 para evitar enumeración.

2.2 Flujo de Autenticación JWT

El administrador envía sus credenciales al endpoint POST /auth/login. El backend valida contra la base de datos (tabla Usuario, campo password_hash). Si las credenciales son válidas, retorna un token JWT firmado. El token se incluye en el header Authorization: Bearer <token> de todas las peticiones al panel de administración. Los tokens tienen expiración configurable (recomendado: 24 horas).

2.3 Cabeceras de Seguridad

Todas las respuestas del backend incluyen cabeceras de seguridad mediante Helmet: Content-Security-Policy (CSP), X-Content-Type-Options: nosniff, X-Frame-Options: DENY (prevención de clickjacking), Strict-Transport-Security (HSTS). CORS restringido exclusivamente a los dominios del frontend (Vercel) y panel admin.

3. Endpoints de la API

A continuación se documentan todos los endpoints organizados por módulo funcional. Cada endpoint incluye método HTTP, ruta, descripción, nivel de autenticación requerido, DTOs de request/response y códigos de estado posibles.

3.1 Módulo: Autenticación

Gestiona el login del administrador al panel y la validación de credenciales. Corresponde al flujo del Diagrama de Actividad #2 (Gestión del Administrador).

Método	Ruta	Descripción	Auth
POST	/auth/login	Iniciar sesión del administrador	No
POST	/auth/logout	Cerrar sesión (invalidar token)	JWT
GET	/auth/me	Obtener datos del usuario autenticado	JWT

POST /auth/login

Descripción: Autentica al administrador y retorna un token JWT. Tras 5 intentos fallidos consecutivos desde la misma IP, se bloquea temporalmente el acceso.

Request Body:

Campo	Tipo	Req.	Validación	Descripción
username	string	Sí	max: 100	Nombre de usuario del administrador
password	string	Sí	max: 255	Contraseña en texto plano

Respuestas:

Código	Tipo	Descripción
200 OK	LoginResponseDto	Login exitoso. Retorna token JWT y datos del usuario.
401 Unauthorized	ErrorDto	Credenciales inválidas.
429 Too Many Requests	ErrorDto	IP bloqueada tras 5 intentos fallidos.

3.2 Módulo: Tipos de Evento

Gestiona los tipos de evento soportados por la plataforma (Bodas, Quinceañeras, Cumpleaños en el MVP). Cada tipo define campos específicos almacenados como JSONB.

Método	Ruta	Descripción	Auth
GET	/tipos-evento	Listar tipos de evento activos	No
GET	/tipos-evento/:id	Obtener tipo de evento por ID	No
POST	/tipos-evento	Crear nuevo tipo de evento	JWT
PUT	/tipos-evento/:id	Actualizar tipo de evento	JWT
PATCH	/tipos-evento/:id/toggle	Activar/desactivar tipo de evento	JWT

GET /tipos-evento

Descripción: Retorna todos los tipos de evento activos. Usado por la landing page para mostrar el catálogo y por el panel admin para seleccionar al crear invitaciones.

Response Body (200 OK):

Campo	Tipo	Req.	Validación	Descripción
id	number	—	—	ID del tipo de evento
nombre	string	—	max: 100	Nombre (ej: Boda, Quinceañera)
descripcion	string	—	—	Descripción del tipo de evento
camposEspecificos	JSON	—	—	Campos adicionales por tipo (esquema dinámico)
activo	boolean	—	—	Si está visible en el catálogo

POST /tipos-evento

Request Body:

Campo	Tipo	Req.	Validación	Descripción
nombre	string	Sí	max: 100, unique	Nombre del tipo de evento
descripcion	string	No	—	Descripción detallada
camposEspecificos	JSON	No	JSON válido	Esquema de campos específicos del tipo

3.3 Módulo: Templates

Gestiona los diseños visuales predefinidos por tipo de evento. El MVP requiere mínimo 3 templates por tipo (9 en total). Cada template está asociado a un TipoEvento.

Método	Ruta	Descripción	Auth
GET	/templates	Listar templates (filtro por tipo)	No
GET	/templates/:id	Obtener template por ID	No
GET	/templates/:id/preview	Obtener preview/thumbnail	No
POST	/templates	Crear nuevo template	JWT
PUT	/templates/:id	Actualizar template	JWT
PATCH	/templates/:id/toggle	Activar/desactivar template	JWT

GET /templates

Query Parameters:

Campo	Tipo	Req.	Validación	Descripción
tipoEventoId	number	No	—	Filtrar por tipo de evento
activo	boolean	No	—	Filtrar por estado activo/inactivo

Response Body (200 OK) — Array de:

Campo	Tipo	Req.	Validación	Descripción
id	number	—	—	ID del template
tipoEventoId	number	—	—	FK al tipo de evento
nombre	string	—	max: 150	Nombre del template
thumbnailUrl	string	—	max: 500	URL de la imagen de preview
descripcion	string	—	—	Descripción del diseño
activo	boolean	—	—	Si está disponible para selección

3.4 Módulo: Servicios

Gestiona los servicios adicionales (Confirmación, Cuenta Regresiva, Música, Galería de Fotos, Múltiples Tarjetas). Cada servicio tiene un precio y un flag de si está incluido en el precio base.

Método	Ruta	Descripción	Auth
GET	/servicios	Listar todos los servicios activos	No
GET	/servicios/:id	Obtener servicio por ID	No
POST	/servicios	Crear nuevo servicio	JWT
PUT	/servicios/:id	Actualizar servicio (nombre, precio)	JWT
PATCH	/servicios/:id/toggle	Activar/desactivar servicio	JWT

Response Body (200 OK) — Array de:

Campo	Tipo	Req.	Validación	Descripción
id	number	—	—	ID del servicio
nombre	string	—	max: 100	Nombre del servicio
descripcion	string	—	—	Descripción detallada
precio	number	—	decimal(12,2)	Precio en ARS (0 si incluido en base)
incluidoEnBase	boolean	—	—	Si está incluido en el precio base
activo	boolean	—	—	Si está disponible

3.5 Módulo: Pedidos

Gestiona el flujo de solicitudes del anfitrión desde la landing page. Corresponde al Diagrama de Actividad #1 (Pedido del Anfitrión). El pedido se crea con estado PENDIENTE y evoluciona a CONTACTADO, COMPLETADO o CANCELADO según la gestión del administrador.

Método	Ruta	Descripción	Auth
POST	/pedidos	Crear pedido desde landing page	No
GET	/pedidos	Listar todos los pedidos (admin)	JWT
GET	/pedidos/:id	Obtener pedido por ID	JWT
PATCH	/pedidos/:id/estado	Cambiar estado del pedido	JWT
GET	/pedidos/:id/resumen	Obtener resumen del pedido	No

POST /pedidos

Descripción: Crea un nuevo pedido desde la landing page. Guarda la configuración elegida por el anfitrión (tipo de evento, template, servicios seleccionados) con estado PENDIENTE. Dispara notificación por email al propietario. Corresponde al paso "Presiona Solicitar" del Diagrama de Actividad #1.

Request Body:

Campo	Tipo	Req.	Validación	Descripción
nombreCliente	string	Sí	max: 200	Nombre completo del anfitrión
telefono	string	Sí	max: 30	Teléfono de contacto
email	string	Sí	max: 255, email	Email del anfitrión
tipoEventoId	number	Sí	FK válida	ID del tipo de evento seleccionado
templateId	number	Sí	FK válida	ID del template elegido
serviciosIds	number[]	No	FKs válidas	Array de IDs de servicios seleccionados

Respuestas:

Código	Tipo	Descripción
201 Created	PedidoResponseDto	Pedido creado. Retorna resumen con precio calculado.
400 Bad Request	ValidationErrorDto	Errores de validación en los campos.
422 Unprocessable	ErrorDto	Tipo de evento o template inválido/inactivo.

Lógica de negocio:

El sistema calcula automáticamente precioBase (precio del template) y precioTotal (base + suma de servicios seleccionados). Si el anfitrión selecciona "Múltiples Tarjetas", se aplica automáticamente 50% de descuento en la segunda tarjeta. El estado inicial es PENDIENTE. Se envía email de notificación al propietario con los datos del pedido. La página de confirmación muestra resumen, link a WhatsApp Business e instrucciones de próximos pasos.

PATCH /pedidos/:id/estado

Descripción: Actualiza el estado del pedido. Transiciones válidas: PENDIENTE → CONTACTADO → COMPLETADO | CANCELADO.

Request Body:

Campo	Tipo	Req.	Validación	Descripción
estado	string	Sí	enum	Nuevo estado: CONTACTADO, COMPLETADO, CANCELADO

3.6 Módulo: Invitaciones

Módulo central del sistema. Gestiona la creación, edición y consulta de invitaciones digitales. Corresponde al Diagrama de Actividad #2 (Gestión del Administrador) para la creación y al Diagrama de Actividad #3 (Experiencia del Invitado) para la consulta pública.

Método	Ruta	Descripción	Auth
POST	/invitaciones	Crear nueva invitación (admin)	JWT
GET	/invitaciones	Listar invitaciones (admin)	JWT
GET	/invitaciones/:id	Obtener invitación completa (admin)	JWT
PUT	/invitaciones/:id	Actualizar invitación (admin)	JWT
DELETE	/invitaciones/:id	Eliminar invitación (admin)	JWT
GET	/invitaciones/:id/public	Obtener invitación pública	No
GET	/invitaciones/:id/countdown	Obtener datos de cuenta regresiva	No

POST /invitaciones

Descripción: Crea una invitación completa desde el panel admin. El sistema genera UUID v4 como identificador público, crea el registro en BD, asigna URL pública y opcionalmente genera URLs personalizadas por invitado. Corresponde al flujo completo del Diagrama de Actividad #2.

Request Body (multipart/form-data):

Campo	Tipo	Req.	Validación	Descripción
pedidoId	number	Sí	FK válida	ID del pedido asociado
templateId	number	Sí	FK válida	ID del template seleccionado
tipoEventoId	number	Sí	FK válida	ID del tipo de evento
titulo	string	Sí	max: 200	Título del evento
fechaEvento	date	Sí	ISO 8601	Fecha del evento (YYYY-MM-DD)
horaEvento	time	Sí	HH:mm	Hora del evento
ubicacion	string	Sí	max: 300	Nombre del lugar del evento
direccion	string	Sí	max: 500	Dirección completa
latitud	number	Sí	decimal(10,7)	Latitud para Google Maps
longitud	number	Sí	decimal(10,7)	Longitud para Google Maps
colorPrimario	string	No	hex: #RRGGBB	Color primario personalizado
contrasenaAsistentes	string	No	max: 255	Contraseña para lista de asistentes

maxFotos	number	No	default: 1000	Límite máximo de fotos en galería
camposEspecificos	JSON	No	JSON válido	Campos dinámicos según tipo de evento
serviciosIds	number[]	Sí	FKs válidas	IDs de servicios a habilitar
fotos	File[]	No	MIME: img, max 5	Fotos del anfitrión (hasta 5, 1 para header)
musica	File	No	MP3, max 20MB	Archivo de música MP3

Respuestas:

Código	Tipo	Descripción
201 Created	InvitationResponseDto	Invitación creada. Retorna ID, URL pública y datos.
400 Bad Request	ValidationErrorDto	Errores de validación (DTO + sanitización HTML).
401 Unauthorized	ErrorDto	Token JWT inválido o expirado.
413 Payload Too Large	ErrorDto	Archivos exceden el límite de tamaño.
415 Unsupported Media	ErrorDto	Tipo MIME no permitido (verificación real del archivo).

Lógica de negocio:

Se genera UUID v4 como ID público de la invitación. Se valida tipo MIME real de archivos subidos (no solo extensión). Se sanitiza HTML en todos los campos de texto (prevención XSS). Se sube fotos a Firebase Storage y se almacenan URLs en tabla FotoAnfitrión. Se sube MP3 a Firebase Storage y se crea registro en tabla Musica. Se crean registros en InvitaciónServicio para cada servicio habilitado. La fecha de expiración se calcula como fecha_evento + 3 meses. El estado del pedido asociado se actualiza a COMPLETADO.

GET /invitaciones/:id/public

Descripción: Retorna los datos públicos de una invitación para renderizar la página del evento. Es el endpoint principal consumido por el frontend cuando un invitado abre la URL de la invitación. Corresponde al inicio del Diagrama de Actividad #3 (Experiencia del Invitado).

Query Parameters:

Campo	Tipo	Req.	Validación	Descripción
invitado	string	No	nombre-apellido	Nombre del invitado para saludo personalizado

Response Body (200 OK):

Campo	Tipo	Req.	Validación	Descripción
id	string (UUID)	—	—	ID público de la invitación
titulo	string	—	—	Título del evento
fechaEvento	date	—	—	Fecha del evento
horaEvento	time	—	—	Hora del evento
ubicacion	string	—	—	Nombre del lugar
direccion	string	—	—	Dirección completa
latitud	number	—	—	Coordenada para mapa
longitud	number	—	—	Coordenada para mapa
colorPrimario	string	—	—	Color de personalización
camposEspecificos	JSON	—	—	Datos específicos del tipo
template	TemplateDto	—	—	Datos del template visual
servicios	ServicioDto[]	—	—	Servicios habilitados
fotosAnfitrión	FotoDto[]	—	—	Fotos cargadas por admin
musica	MusicaDto null	—	—	Datos del archivo MP3
historias	HistoriaDto[]	—	—	Secciones de historia (max 3)
saludoPersonalizado	string null	—	—	Saludo si ?invitado presente
tieneConfirmación	boolean	—	—	Si el servicio está habilitado
mostrarBotónConfirmar	boolean	—	—	true solo si ?invitado está presente

3.7 Módulo: Historia

Gestiona las secciones de historia de una invitación. Cada invitación puede tener hasta 3 secciones, cada una con un párrafo de texto (máx. 3000 caracteres) y una imagen. Se sanitiza HTML para prevenir XSS.

Método	Ruta	Descripción	Auth
GET	/invitaciones/:id/historias	Listar secciones de historia	No
POST	/invitaciones/:id/historias	Crear sección de historia	JWT
PUT	/invitaciones/:id/historias/:seccionId	Actualizar sección	JWT
DELETE	/invitaciones/:id/historias/:seccionId	Eliminar sección	JWT

POST /invitaciones/:id/historias

Request Body (multipart/form-data):

Campo	Tipo	Req.	Validación	Descripción
texto	string	Sí	max: 3000 chars	Texto de la sección (sanitizado)
imagen	File	No	MIME: imagen	Foto asociada a la sección
orden	number	Sí	1-3	Posición de la sección

Respuestas:

Código	Tipo	Descripción
201 Created	HistoriaSeccionDto	Sección creada exitosamente.
400 Bad Request	ValidationErrorDto	Texto excede límite o datos inválidos.
409 Conflict	ErrorDto	Ya existen 3 secciones para esta invitación.

3.8 Módulo: Invitados y Confirmación de Asistencia

Gestiona la lista de invitados, URLs personalizadas y confirmación de asistencia. Corresponde a la sección del Diagrama de Actividad #3 donde el invitado presiona "Confirmar Asistencia". El botón solo se muestra si la URL contiene el parámetro ?invitado=nombre-apellido.

Método	Ruta	Descripción	Auth
POST	/invitaciones/:id/invitados	Cargar lista de invitados (JSON)	JWT
GET	/invitaciones/:id/invitados	Listar invitados y estado	JWT
GET	/invitaciones/:id/invitados/export	Exportar URLs personalizadas (CSV)	JWT
POST	/invitaciones/:id/confirmar	Confirmar asistencia de invitado	No
GET	/invitaciones/:id/asistentes	Ver lista de asistentes	Contraseña

POST /invitaciones/:id/invitados

Descripción: Carga masiva de invitados desde un archivo JSON. El sistema genera automáticamente URLs personalizadas para cada invitado. Corresponde al paso "Carga JSON con lista de invitados" del Diagrama de Actividad #2.

Request Body:

Campo	Tipo	Req.	Validación	Descripción
invitados	Invitado[]	Sí	array no vacío	Lista de invitados a cargar
invitados[].nombre	string	Sí	max: 100	Nombre del invitado
invitados[].apellido	string	Sí	max: 100	Apellido del invitado

Response Body (201 Created):

Campo	Tipo	Req.	Validación	Descripción
totalInvitados	number	—	—	Total de invitados cargados
urlsGeneradas	UrlInvitado[]	—	—	Array con nombre y URL personalizada
csvDownloadUrl	string	—	—	URL para descargar CSV con todas las URLs

POST /invitaciones/:id/confirmar

Descripción: Registra la confirmación de asistencia de un invitado. Solo la primera confirmación se registra (idempotente). El invitado se identifica por el parámetro de la URL.

Request Body:

Campo	Tipo	Req.	Validación	Descripción
nombre	string	Sí	max: 100	Nombre del invitado (del parámetro URL)
apellido	string	Sí	max: 100	Apellido del invitado

Respuestas:

Código	Tipo	Descripción
200 OK	ConfirmacionDto	Confirmación registrada (o ya existente).
404 Not Found	ErrorDto	Invitado no encontrado en esta invitación.

GET /invitaciones/:id/asistentes

Descripción: Retorna la lista de asistentes con su estado de confirmación. Requiere contraseña del evento (proporcionada por admin al anfitrión).

Headers requeridos:

Campo	Tipo	Req.	Validación	Descripción
X-Event-Password	string	Sí	—	Contraseña única del evento

Response Body (200 OK):

Campo	Tipo	Req.	Validación	Descripción
totalEsperados	number	—	—	Total de invitados cargados
totalConfirmados	number	—	—	Cantidad de confirmaciones
invitados	InvitadoEstado[]	—	—	Lista con nombre, apellido, confirmado, fecha

3.9 Módulo: Galería de Fotos

Gestiona la galería colaborativa de fotos de cada evento. Los invitados acceden escaneando un código QR. En el MVP, la subida de fotos no requiere autenticación. El administrador puede eliminar fotos desde el panel. Máximo 1000 fotos por invitación, 15 MB por archivo. Almacenamiento en Firebase Storage con retención de 3 meses post-evento.

Método	Ruta	Descripción	Auth
GET	/invitaciones/:id/galeria	Listar fotos de la galería	No
POST	/invitaciones/:id/galeria	Subir foto a la galería	No
DELETE	/invitaciones/:id/galeria/:fotoId	Eliminar foto (admin)	JWT
GET	/invitaciones/:id/galeria/download	Descargar todas las fotos (ZIP)	No
GET	/invitaciones/:id/galeria/stats	Estadísticas de almacenamiento	JWT

Ya no es JWT
ahora usa contraseña

POST /invitaciones/:id/galeria

Descripción: Sube una foto a la galería compartida del evento. Acceso público (sin auth en MVP). Valida tipo MIME real del archivo y tamaño máximo. Almacena en Firebase Storage.

Request Body (multipart/form-data):

Campo	Tipo	Req.	Validación	Descripción
foto	File	Sí	MIME: image/*	Archivo de imagen

Validaciones:

Verificación MIME real del contenido (no solo extensión). Tamaño máximo 15 MB por archivo. Formatos aceptados: JPEG, PNG, WebP, GIF. Se verifica que la galería no haya alcanzado el límite de max_fotos (por defecto 1000). Se rechaza si la invitación está expirada.

Respuestas:

Código	Tipo	Descripción
201 Created	FotoResponseDto	Foto subida exitosamente. Retorna URL y metadatos.
400 Bad Request	ErrorDto	Archivo no proporcionado o formato inválido.
409 Conflict	ErrorDto	Galería llena (límite de fotos alcanzado).
413 Payload Too Large	ErrorDto	Archivo excede 15 MB.

415 Unsupporte d Media	ErrorDto	Tipo MIME no permitido.
---------------------------------------	----------	-------------------------

GET /invitaciones/:id/galeria/download

Descripción: Genera y descarga un archivo ZIP con todas las fotos de la galería.

Respuestas:

Código	Tipo	Descripción
200 OK	application/zip	Archivo ZIP con todas las fotos.
404 Not Found	ErrorDto	Invitación no encontrada o galería vacía.

3.10 Módulo: Música

Gestiona el archivo MP3 asociado a una invitación. Cada invitación puede tener máximo un archivo de música. Se reproduce automáticamente con volumen bajo tras aceptar el modal de bienvenida (Diagrama de Actividad #3).

Método	Ruta	Descripción	Auth
GET	/invitaciones/:id/musica	Obtener datos de la música	No
POST	/invitaciones/:id/musica	Subir archivo MP3	JWT
DELETE	/invitaciones/:id/musica	Eliminar música	JWT

POST /invitaciones/:id/musica

Request Body (multipart/form-data):

Campo	Tipo	Req.	Validación	Descripción
archivo	File	Sí	MP3, max 20MB	Archivo de música en formato MP3

Validaciones: Tipo MIME verificado como audio/mpeg. Tamaño máximo 20 MB. Solo un archivo por invitación (reemplaza el existente).

3.11 Módulo: Notificaciones y Automatizaciones

Gestiona las notificaciones automáticas por email y los procesos programados (cron jobs). Las notificaciones se disparan por eventos del sistema y no exponen endpoints públicos. El cron job de eliminación se ejecuta cada noche.

Método	Ruta	Descripción	Auth
GET	/notificaciones	Listar notificaciones enviadas	JWT
POST	/notificaciones/test	Enviar notificación de prueba	JWT

Eventos que disparan notificaciones

NUEVO_PEDIDO: Se envía al propietario cuando un anfitrión completa el formulario de pedido en la landing page. Incluye nombre del cliente, tipo de evento, servicios seleccionados y precio total.

EXPIRACION_PROXIMA: Se envía al anfitrión 7 días y 3 días antes de la eliminación automática de su invitación y galería. Le recuerda descargar las fotos antes de la eliminación definitiva.

AVISO_ELIMINACION: Se registra internamente cuando el cron job ejecuta la eliminación de datos (hard delete de invitación, galería y registros en BD). Se genera un LogEliminacion con fecha, cantidad de fotos eliminadas y detalles.

Cron Job: Eliminación automática de datos

Se ejecuta cada noche a las 02:00 AM. Identifica invitaciones cuyo evento ocurrió hace más de 3 meses (`fecha_expiracion < NOW()`). Ejecuta hard delete del registro en BD, eliminación de galería de fotos en Firebase Storage, eliminación de archivo MP3 en Firebase Storage. Registra LogEliminacion con `invitacion_id_ref`, fecha, fotos eliminadas y detalles. Los logs de eliminación se retienen por 6 meses.

3.12 Módulo: Cálculo de Precios

Endpoint utilitario para calcular el precio en tiempo real según la configuración seleccionada por el anfitrión en la landing page (Diagrama de Actividad #1). Debe responder en menos de 100ms.

Método	Ruta	Descripción	Auth
POST	/precios/calcular	Calcular precio dinámico	No

POST /precios/calcular

Request Body:

Campo	Tipo	Req.	Validación	Descripción
serviciosIds	number[]	Sí	FKs válidas	IDs de servicios seleccionados
segundaTarjeta	boolean	No	default: false	Si incluye segunda versión de tarjeta

Response Body (200 OK):

Campo	Tipo	Req.	Validación	Descripción
precioBase	number	—	—	Precio base de la invitación (\$30.000)
servicios	DetalleServicio[]	—	—	Desglose de servicios con nombre y precio
descuento	number	—	—	Descuento aplicado (50% si segunda tarjeta)
precioTotal	number	—	—	Precio final calculado

4. Esquema de Respuestas y Manejo de Errores

4.1 Estructura de Respuesta Exitosa

Todas las respuestas exitosas siguen el formato estándar con los datos directamente en el body para endpoints individuales, o envueltos en un objeto de paginación para listados.

Respuesta individual:

```
{ "id": "uuid", "titulo": "Mi Boda", "fechaEvento": "2026-06-15", ... }
```

Respuesta paginada:

```
{ "data": [...], "meta": { "page": 1, "limit": 20, "total": 45, "totalPages": 3 } }
```

4.2 Estructura de Error

Todos los errores retornan un objeto ErrorDto consistente:

Campo	Tipo	Req.	Validación	Descripción
statusCode	number	—	—	Código HTTP del error
error	string	—	—	Tipo de error (ej: Bad Request)
message	string string[]	—	—	Descripción del error o array de errores de validación
timestamp	string	—	ISO 8601	Momento del error

4.3 Códigos de Estado HTTP

Código	Estado	Uso
200	OK	Operación exitosa (GET, PATCH, PUT)
201	Created	Recurso creado exitosamente (POST)
204	No Content	Eliminación exitosa (DELETE)
400	Bad Request	Datos de entrada inválidos o malformados
401	Unauthorized	Token JWT ausente, inválido o expirado
403	Forbidden	Contraseña de evento incorrecta
404	Not Found	Recurso no encontrado
409	Conflict	Conflicto de estado (ej: galería llena, secciones al máximo)
413	Payload Too Large	Archivo excede límite de tamaño (15/20 MB) o request > 16 MB
415	Unsupported Media	Tipo MIME no permitido (verificación real del contenido)
422	Unprocessable	Entidad semánticamente inválida (ej: FK a recurso inactivo)

429	Too Many Requests	Rate limit excedido (100 req/min) o bloqueo por fuerza bruta
500	Internal Error	Error interno del servidor

5. Esquema de Base de Datos

El modelo de datos se basa en el Diagrama Entidad-Relación y el Diagrama de Clases del sistema. PostgreSQL es el motor de base de datos, con TypeORM como ORM (parámetros preparados para prevenir inyección SQL). A continuación se documenta cada entidad con sus campos, tipos, restricciones y relaciones.

5.1 Entidad: Usuario

Almacena las credenciales del administrador del sistema. En el MVP existe un único usuario con rol ADMIN.

Campo	Tipo SQL	Clave	Restricciones
id	SERIAL	PK	Auto-incremental
username	VARCHAR(100)	—	NOT NULL, UNIQUE
email	VARCHAR(255)	—	NOT NULL
password_hash	VARCHAR(255)	—	NOT NULL (Argon2/bcrypt)
role	VARCHAR(20)	—	DEFAULT 'ADMIN'
created_at	TIMESTAMP	—	DEFAULT NOW()

5.2 Entidad: TipoEvento

Define los tipos de evento soportados. Los campos específicos por tipo se almacenan como JSONB para flexibilidad.

Campo	Tipo SQL	Clave	Restricciones
id	SERIAL	PK	Auto-incremental
nombre	VARCHAR(100)	—	NOT NULL, UNIQUE
descripcion	TEXT	—	Nullable
campos_especificos	JSONB	—	Esquema dinámico por tipo
activo	BOOLEAN	—	DEFAULT TRUE

5.3 Entidad: Pedido

Registra las solicitudes de invitaciones desde la landing page. Evoluciona por estados: PENDIENTE → CONTACTADO → COMPLETADO | CANCELADO.

Campo	Tipo SQL	Clave	Restricciones
id	SERIAL	PK	Auto-incremental

tipo_evento_id	INT	FK	→ TipoEvento.id, NOT NULL
template_id	INT	FK	→ Template.id, NOT NULL
nombre_cliente	VARCHAR(200)	—	NOT NULL
telefono	VARCHAR(30)	—	NOT NULL
email	VARCHAR(255)	—	NOT NULL
precio_base	DECIMAL(12,2)	—	NOT NULL
precio_total	DECIMAL(12,2)	—	NOT NULL
estado	VARCHAR(20)	—	DEFAULT 'PENDIENTE'
created_at	TIMESTAMP	—	DEFAULT NOW()

5.4 Entidad: Invitacion (Central)

Tabla central del sistema. Cada invitación tiene un UUID v4 como identificador público, está asociada a un pedido, template y tipo de evento, y contiene toda la información del evento.

Campo	Tipo SQL	Clave	Restricciones
id	UUID	PK	DEFAULT gen_random_uuid()
pedido_id	INT	FK	→ Pedido.id
template_id	INT	FK	→ Template.id, NOT NULL
tipo_evento_id	INT	FK	→ TipoEvento.id
titulo	VARCHAR(200)	—	NOT NULL
fecha_evento	DATE	—	NOT NULL
hora_evento	TIME	—	NOT NULL
ubicacion	VARCHAR(300)	—	NOT NULL
direccion	VARCHAR(500)	—	NOT NULL
latitud	DECIMAL(10,7)	—	NOT NULL
longitud	DECIMAL(10,7)	—	NOT NULL
color_primario	VARCHAR(7)	—	Hex color (#RRGGBB)
contrasena_asistentes	VARCHAR(255)	—	Para lista de asistentes
max_fotos	INT	—	DEFAULT 1000
campos_especificos	JSONB	—	Datos dinámicos del evento
activa	BOOLEAN	—	DEFAULT TRUE
created_at	TIMESTAMP	—	DEFAULT NOW()
fecha_expiracion	DATE	—	NOT NULL (evento + 3 meses)

5.5 Relaciones Principales

Invitacion tiene relaciones 1:N con Invitado, HistoriaSeccion (máx. 3), Foto (máx. 1000), FotoAnfitrión (máx. 5). Relación 1:1 con Musica. Relación M:N con Servicio a través de la tabla intermedia InvitacionServicio. Pedido tiene relación M:N con Servicio a través de PedidoServicio (con precio capturado al momento de la solicitud). Template pertenece a TipoEvento (N:1). LogEliminacion referencia Invitacion por UUID (referencia blanda post-eliminación).

5.6 Entidades Complementarias

Las tablas PedidoServicio e InvitacionServicio son tablas intermedias para relaciones muchos-a-muchos. PedidoServicio captura el precio_al_momento para mantener historial de

precios. InvitacionServicio tiene un flag habilitado para activar/desactivar servicios por invitación. Las tablas Foto, FotoAnfitrión, Musica e HistoriaSeccion almacenan URLs de Firebase Storage y metadatos (tamaño, MIME type, orden). La tabla Invitado almacena nombre, apellido, estado de confirmación y fecha de confirmación. LogEliminacion registra cada eliminación automática con invitacion_id_ref (UUID), fecha, fotos eliminadas y detalles.

6. Validaciones y Sanitización

6.1 Validación en Capas

Toda validación implementada en el frontend (React) se replica obligatoriamente en el backend (NestJS). No se permiten inserciones directas a la base de datos sin pasar por el DTO validado. Los DTOs de NestJS utilizan class-validator y class-transformer para validación automática.

6.2 Sanitización HTML

Todos los campos de texto que aceptan entrada del usuario (especialmente en el módulo de Historia) se sanitizan para eliminar etiquetas <script>, eventos inline (onmouseover, onclick, etc.) y cualquier HTML potencialmente peligroso. Esto previene ataques XSS (Cross-Site Scripting).

6.3 Verificación MIME

Para archivos subidos (fotos y música), el backend valida que el contenido real del archivo coincida con la extensión declarada. No se confía únicamente en el nombre del archivo o el Content-Type enviado por el cliente. Extensiones permitidas para fotos: .jpg, .jpeg, .png, .webp, .gif. Para música: .mp3 (audio/mpeg).

6.4 Límites de Tamaño

Recurso	Límite	Acción al exceder
Foto de galería	15 MB por archivo	413 Payload Too Large
Archivo MP3	20 MB	413 Payload Too Large
Texto de historia	3.000 caracteres	400 Bad Request (truncado)
Fotos por invitación	1.000 archivos	409 Conflict
Secciones de historia	3 por invitación	409 Conflict
Fotos del anfitrión	5 por invitación	409 Conflict
Request payload	16 MB	413 Payload Too Large
Campos de texto	maxLength por esquema	400 Bad Request

7. Resumen Completo de Endpoints

Tabla consolidada de todos los endpoints de la API organizados por módulo.

Método	Ruta	Descripción	Auth
POST	/auth/login	Login administrador	No
POST	/auth/logout	Logout administrador	JWT
GET	/auth/me	Datos del usuario autenticado	JWT
GET	/tipos-evento	Listar tipos de evento	No
GET	/tipos-evento/:id	Obtener tipo de evento	No
POST	/tipos-evento	Crear tipo de evento	JWT
PUT	/tipos-evento/:id	Actualizar tipo de evento	JWT
PATCH	/tipos-evento/:id/toggle	Toggle activo/inactivo	JWT
GET	/templates	Listar templates	No
GET	/templates/:id	Obtener template	No
GET	/templates/:id/preview	Preview del template	No
POST	/templates	Crear template	JWT
PUT	/templates/:id	Actualizar template	JWT
PATCH	/templates/:id/toggle	Toggle activo/inactivo	JWT
GET	/servicios	Listar servicios	No
GET	/servicios/:id	Obtener servicio	No
POST	/servicios	Crear servicio	JWT
PUT	/servicios/:id	Actualizar servicio	JWT
PATCH	/servicios/:id/toggle	Toggle activo/inactivo	JWT
POST	/pedidos	Crear pedido (landing)	No
GET	/pedidos	Listar pedidos	JWT
GET	/pedidos/:id	Obtener pedido	JWT
PATCH	/pedidos/:id/estado	Cambiar estado	JWT
GET	/pedidos/:id/resumen	Resumen del pedido	No
POST	/invitaciones	Crear invitación	JWT
GET	/invitaciones	Listar invitaciones	JWT
GET	/invitaciones/:id	Obtener invitación (admin)	JWT
PUT	/invitaciones/:id	Actualizar invitación	JWT
DELETE	/invitaciones/:id	Eliminar invitación	JWT

GET	/invitaciones/:id/public	Invitación pública	No
GET	/invitaciones/:id/countdown	Datos cuenta regresiva	No
POST	/invitaciones/:id/historias	Crear sección historia	JWT
PUT	/invitaciones/:id/historias/:sId	Actualizar sección	JWT
DELETE	/invitaciones/:id/historias/:sId	Eliminar sección	JWT
POST	/invitaciones/:id/invitados	Cargar invitados (JSON)	JWT
GET	/invitaciones/:id/invitados	Listar invitados	JWT
GET	/invitaciones/:id/invitados/export	Exportar URLs (CSV)	JWT
POST	/invitaciones/:id/confirmar	Confirmar asistencia	No
GET	/invitaciones/:id/asistentes	Lista de asistentes	Pass
GET	/invitaciones/:id/galeria	Listar fotos galería	No
POST	/invitaciones/:id/galeria	Subir foto	No
DELETE	/invitaciones/:id/galeria/:fId	Eliminar foto	JWT
GET	/invitaciones/:id/galeria/download	Descargar ZIP	No
GET	/invitaciones/:id/galeria/stats	Stats almacenamiento	JWT
GET	/invitaciones/:id/musica	Obtener música	No
POST	/invitaciones/:id/musica	Subir MP3	JWT
DELETE	/invitaciones/:id/musica	Eliminar música	JWT
POST	/precios/calcular	Calcular precio dinámico	No
GET	/notificaciones	Listar notificaciones	JWT

Total de endpoints: 48

Endpoints públicos (sin auth): 20

Endpoints protegidos (JWT): 27

Endpoints con contraseña de evento: 1